單元 9 · 健康科技研究方法 · Research Methodology

# 法規與品質（軟體醫材 SaMD）

SaMD Regulation & Quality — 你的 App/ 演算法，可能就是一個『醫療器材』

涵蓋： SaMD 定義 · IMDRF 風險分級 · ISO 13485/14971 · IEC 62304 · MDR/FDA/TFDA · AI 醫材 (GMLP/PCCP)

實例：一個 AI 視網膜病變篩檢軟體，從『算不算醫材』到上市與上市後管理

先修： 9.5 醫療 AI · 9.7 可用性 · 對應： IMDRF / ISO / IEC / MDR / FDA / 醫療器材管理法 · S2

本簡報五個部分 Five Parts

# 課程地圖 Course Map

從『你的產品算不算醫材』一路走到『上市與上市後品質管理』

| 部分 | 主題 | 你會學到 |
| --- | --- | --- |
| Part 1 | 什麼是 SaMD | 定義、意圖用途決定一切、 IMDRF 風險分級 |
| Part 2 | 品質與風險三支柱 | ISO 13485 （品質）、 ISO 14971 （風險）、 IEC 62304 （軟體） |
| Part 3 | 上市路徑 | 歐盟 MDR 、美國 FDA 、台灣 TFDA 三地比較 |
| Part 4 | AI/ML 醫材的特殊挑戰 | 鎖定 vs 持續學習、 GMLP 、變更控制計畫 PCCP |
| Part 5 | 實務與實例 | 從意圖用途到上市後： AI 篩檢軟體全程 · 作業 |

**教學重點** 一句話抓重點：很多健康科技團隊最震撼的一課是——『我做的 App/ 演算法，在法律上可能就是一個醫療器材』。一旦是醫材，就要走品質系統、風險管理、法規查驗登記。這一課帶你搞懂『算不算、屬於哪一級、怎麼上市、上市後怎麼管』——這是產品能不能合法賣、被採用的關鍵。

Opening

# 為什麼健康科技研究者一定要懂法規?

做出來、證明有效，還要『合法上市』才用得到

| ✗ 不懂法規的下場 | ✓ 懂法規，你能 |
| --- | --- |
| 以為只是健康 App，其實是醫材 → 違法上市 | 及早判斷：算不算醫材、屬第幾級 |
| 沒建品質系統（QMS），做完才發現要重來 | 從開發就內建品質、風險、軟體流程 |
| 沒做風險管理，出事無法追溯與課責 | 選對上市路徑（MDR／FDA／TFDA） |
| AI 模型一改版就要重送審 → 動彈不得 | 用 PCCP 讓 AI 模型合法地持續更新 |

**教學重點** 定位：這一課是單元 9『從研究到落地』的最後拼圖——前面教你做出有效 (9.4/9.5)、好用 (9.7)、能落地 (9.6/9.8) 的產品，這一課教你讓它『合法上市』。法規不是研究的敵人，而是把『研究原型』變成『可上市醫材』必經的品質與安全門檻。及早懂，才不會做完才發現要打掉重練。

1

PART 1

# 什麼是 SaMD

## Is Your Software a Medical Device?

對應： IMDRF 定義與風險分級

最關鍵的第一問：你的軟體『算不算』醫療器材?
答案不看技術多炫，而看『意圖用途』。

# SaMD 是什麼？軟體『本身』就是醫材

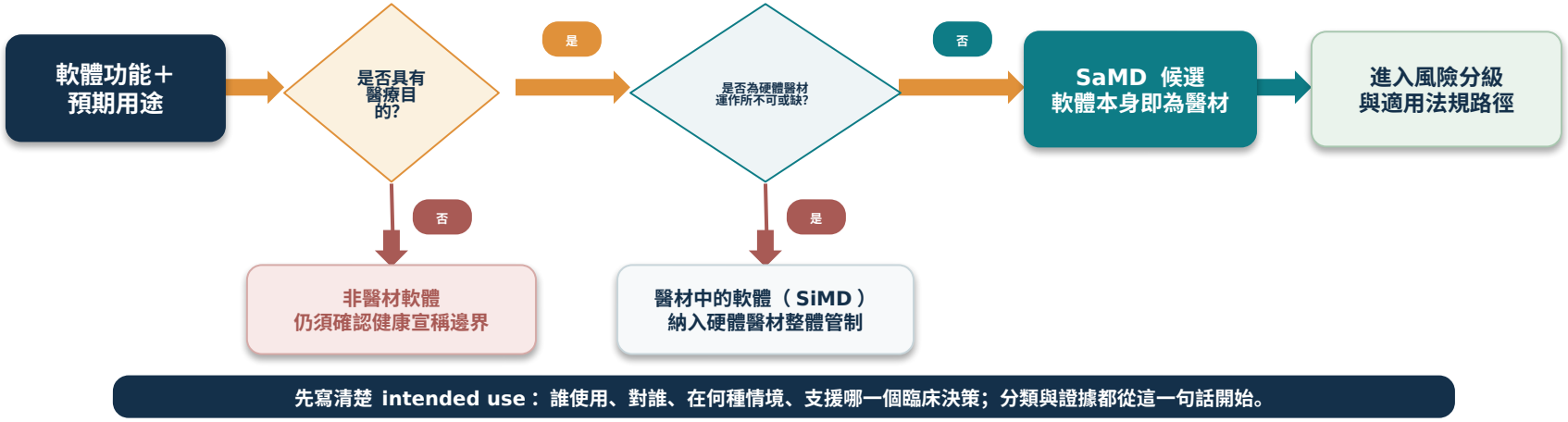
不是附在硬體裡，而是軟體獨立達成醫療目的




**教學重點**　觀念校正：SaMD 指『軟體本身就是醫療器材』——它不需要附著在任何硬體上，光靠軟體就達成醫療目的（診斷、治療、預防、監測）。這和『嵌在硬體裡的軟體 (SiMD)』不同。一個手機 App、一段雲端演算法，都可能是 SaMD。判斷的關鍵不是它多複雜，而是它『宣稱要做什麼』。

# 它是 SaMD 嗎？從功能到法規邊界的判定

以 intended use 為起點，先判斷醫療目的與硬體依賴，再進入 SaMD 風險分類；名稱與技術形式本身不能決定法規屬性。




來源：IMDRF SaMD N10／N12；EU MDCG 2019-11 rev.1（2025）；TFDA 醫療器材軟體分類參考指引

**教學提醒：不要從「用了 AI、App 或雲端」反推它是醫材。先用一句可稽核的預期用途描述臨床目的，再逐步判斷資格、邊界、分類與證據需求。**

# 決定關鍵：意圖用途 (intended use)

同樣的技術，宣稱不同 → 是不是醫材就不同

**同一套演算法，換一句宣稱 → 判定就不同**




**教學重點**　最重要的一課：是不是醫材，看『你宣稱它要做什麼 (intended use)』，不是看技術。同一套心律演算法，宣稱『幫你了解運動強度』可能不是醫材，宣稱『偵測心房顫動、建議就醫』就很可能是。所以行銷文案、仿單、宣稱都要小心——一句話可能就讓你的產品從『App』變成『需查驗登記的醫材』。

# 判定練習：這六個產品算不算醫材?

先看宣稱，再看是否符合 FDA 『非醫材 CDS 』四條件

**計步＋心情日記**

非醫材

一般健康促進

**醫院排班系統**

非醫材

行政管理，無醫療目的

**用藥時間提醒**

通常非醫材

只提醒、不改劑量

**給醫師看的用藥交互作用提示（列出依據文獻）**

可能非醫材

符合 CDS 四條件時

**胰島素劑量計算 App （病人自用）**

醫材

直接決定治療劑量

**AI 判讀皮膚照片是否為黑色素瘤**

醫材

處理影像＋診斷

**FDA 非醫材 CDS 四條件**

（四項都要符合）

1. 不處理醫學影像或生理訊號
2. 顯示／分析醫療資訊
3. 給醫療人員建議，而非取代判斷
4. 醫療人員能自己檢視建議的依據

**教學重點** 判定順序：① 有醫療目的嗎？（沒有→非醫材）② 有的話，是不是給醫師參考、且醫師能自己看懂依據？（ FDA 對符合四條件的臨床決策支援軟體不列為醫材）③ 其餘依 IMDRF ／各國規則分級。結論仍以主管機關判定為準。

# IMDRF 風險分級：資訊重要性 × 病況嚴重度

兩個維度交叉，決定風險類別 I–IV

資訊重要性 ↓

| | 非嚴重 | 嚴重 | 危急 |
|---|---|---|---|
| 提供資訊 Inform | I | I | II |
| 驅動臨床處置 Drive | I | II | III |
| 治療／診斷 Treat ／ Diagnose | II | III | IV |

病況嚴重度 →

**怎麼讀**

越往右下，風險越高、審查越嚴

**I 最低 → IV 最高**

先想清楚風險，再對應各國正式分級

**教學重點** 怎麼讀這張表：風險＝『這軟體的資訊有多關鍵（只是參考→驅動處置→直接診療）』 × 『病人的病況有多嚴重（非嚴重→嚴重→危急）』。右下角（治療 / 診斷 × 危急）＝ Category IV，風險最高、審查最嚴；左上角（提供資訊 × 非嚴重）＝ Category I，最低。這個框架幫你『先想清楚風險』，再對應各國的正式分級。

# IMDRF SaMD 風險分類矩陣

以「軟體資訊對醫療決策的重要性」交叉「醫療情況／病況嚴重度」，得到 Category I–IV；分類反映潛在影響，而非單看演算法複雜度。

| 醫療情況／病況（嚴重度） | 治療或診斷 | 驅動臨床管理 | 告知臨床管理 |
|---|---|---|---|
| 危急 Critical | Category IV ｜最高影響 | Category III ｜高影響 | Category II ｜中度影響 |
| 嚴重 Serious | Category III ｜高影響 | Category II ｜中度影響 | Category I ｜低影響 |
| 非嚴重 Non-serious | Category II ｜中度影響 | Category I ｜低影響 | Category I ｜低影響 |

資訊越直接改變治療／診斷，且病況越危急，分類越高；Category IV 最高、Category I 最低。

來源：IMDRF SaMD N12—Risk Categorization Framework

**教學提醒：先問輸出是在治療／診斷、驅動管理，還是僅提供資訊；再問錯誤輸出發生於危急、嚴重或非嚴重情境。兩軸都要由 intended use 與可合理預見的誤用支撐。**

2

PART 2

# 品質與風險三支柱

## Quality, Risk & Software Standards

對應： ISO 13485 · ISO 14971 · IEC 62304

醫材不是『做出來能動就好』，而是要證明『在一套品質系統下、有管理風險、有嚴謹的軟體流程』做出來的。三大標準是地基。

# 三大標準：品質、風險、軟體流程

國際通用，各國法規多要求或認可

**醫材軟體：合法上市**

| ISO 13485 | ISO 14971 | IEC 62304 |
|---|---|---|
| **組織層級**<br>**品質管理系統 QMS**<br>整個組織怎麼有品質地做醫材 | **風險層級**<br>**風險管理**<br>系統性辨識、評估、控制風險 | **軟體層級**<br>**醫材軟體生命週期**<br>開發、測試、維護的流程要求 |

**＋ IEC 62366-1 可用性工程（接 9.7）　＋資安**　——從第一天就內建，不是事後補文件

**教學重點**　三支柱各司其職：ISO 13485 是『組織層級』的品質系統（流程、文件、追溯）；ISO 14971 是『風險層級』（把危害找出來、降到可接受）；IEC 62304 是『軟體層級』（開發、測試、維護的流程）。再加 IEC 62366（可用性，接 9.7）與資安。這些不是做完產品才補的文件，而是要『從第一天就內建』的做事方式。

# ISO 13485： 品質管理系統 (QMS)

不是產品標準，是『你這家組織怎麼做事』的標準




**不是產品標準**
是『你這家組織怎麼做事』的標準：誰做了什麼、為什麼，都能追溯

**新創最常見痛點**
做完 MVP 才想建 QMS → 沒設計管制紀錄、沒可追溯性 → 打掉重來
**→ 越早（哪怕精簡）導入越省事**

**教學重點** 新創的血淚教訓： ISO 13485 是『組織如何有品質地開發與維護醫材』的系統——不是等產品做完再補的文件堆。很多團隊埋頭做完 MVP 才發現：沒有設計管制紀錄、沒有可追溯性，等於要打掉重來。及早（哪怕精簡地）建立 QMS ，是把研究原型變成可上市醫材最關鍵、也最常被低估的一步。

# ISO 14971： 風險管理

把『可能傷害病人的地方』找出來、降到可接受

| ① 辨識危害 | ② 估計風險 | ③ 風險控制 | ④ 殘餘風險 | ⑤ 效益 - 風險＋監測 |
|---|---|---|---|---|
| 列出所有可能的傷害來源<br>SaMD 常見：誤判、當機、資料錯誤、被誤用、資安漏洞 | 嚴重度 × 發生機率<br>用風險矩陣排序 | 用設計降低風險<br>防呆、警示、限制；高風險輸出加二次確認（接 9.7） | 控制後還剩多少？可接受嗎？ | 整體效益大於風險？<br>上市後持續監測新風險 |

**教學重點** 風險管理是醫材的靈魂： ISO 14971 要你系統性地問『哪裡會傷到病人、有多嚴重、多可能發生、怎麼降低』。對 SaMD，危害常來自『誤判、當機、資料錯誤、被誤用、資安漏洞』。控制手段常是設計（接 9.7 人因）——例如高風險輸出加二次確認。最後要做『效益 - 風險』整體判斷，並在上市後持續監測新風險。

# IEC 62304： 軟體安全分級 A/B/C

## 失效可能造成的傷害越大，開發流程要越嚴謹

**分級看：萬一軟體失效，最糟會造成什麼傷害?**

**Class A**
失效可能：不會造成傷害
**流程：最基本**

**Class B**
失效可能：可能傷害，但不嚴重
**流程：中等嚴謹**

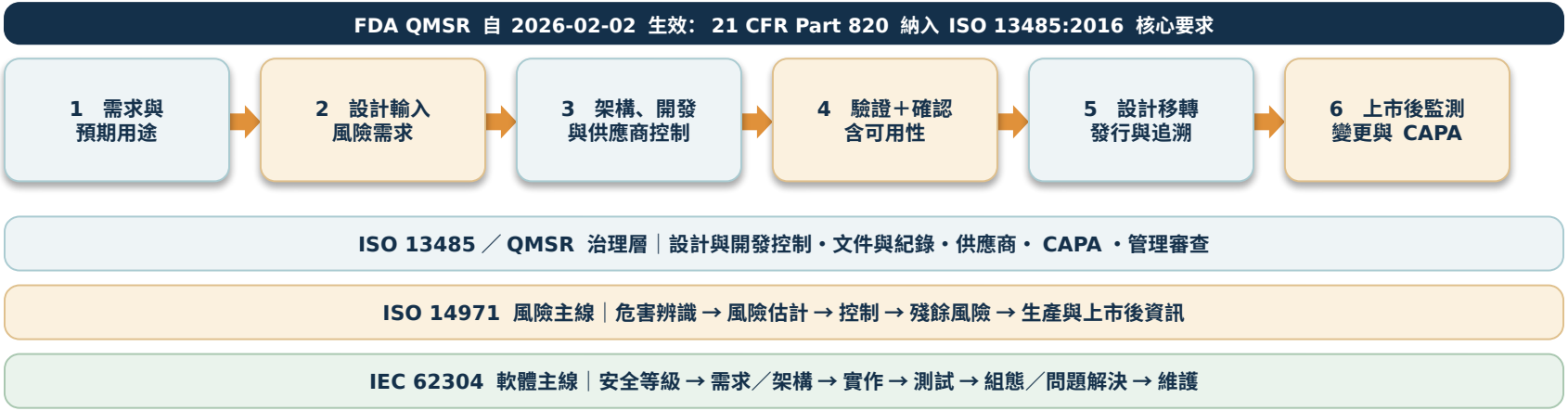
**Class C**
失效可能：可能死亡或嚴重傷害
**流程：最嚴謹：完整架構、單元測試、追溯**

**關鍵**
分級不是評軟體多安全，而是決定開發流程要多嚴謹
可用風險控制降級，但要有依據

**教學重點** 關鍵觀念： IEC 62304 的分級『不是評你的軟體有多安全』，而是決定『你的開發流程要多嚴謹』。分級看『萬一軟體失效，最糟會造成什麼傷害』——不會傷人 (A) 、可能小傷 (B) 、可能致命 (C) 。 Class C 要求最完整的架構設計、單元測試、追溯。可用風險控制把某些部分降級，但要有依據。這是軟體開發流程的法規地基。

# 把 QMS、風險管理與軟體生命週期接成同一條證據鏈

ISO 13485 ／ FDA QMSR 提供治理骨架，ISO 14971 讓風險活動貫穿生命週期，IEC 62304 管理軟體開發與維護；三者不是平行文件。




來源：FDA QMSR （2026）； ISO 13485； ISO 14971； IEC 62304

**教學提醒：稽核時真正有說服力的是可追溯性：需求連到危害與風險控制，控制連到設計輸入、驗證測試、殘餘風險與上市後訊號。文件多不等於系統有效。**

# 技術文件長什麼樣？一張追溯矩陣串起全部

審查者要的不是文件堆，而是『需求 → 風險 → 設計 → 測試』每一格都對得上

**常見文件清單**

- 意圖用途聲明
- 軟體需求規格 SRS
- 架構與設計文件
- 風險管理檔案
- 驗證與確認報告 V&V
- 可用性工程檔案
- 組態／版本管理＋ SBOM

**追溯矩陣（示範一列）**

| | |
|---|---|
| 需求 | REQ-07： 分數 ≥ 閾值時顯示『建議轉診』 |
| 危害 | HAZ-03： 偽陰性 → 延誤就醫 |
| 風險控制 | RC-05： 灰區結果強制顯示『請醫師複判』 |
| 驗證 | TST-21： 外部驗證集敏感度 ≥ 預設目標 |
| 可用性 | UT-04： 10 位使用者都看得懂提示 |

**教學重點**　追溯矩陣是三支柱的交會點：每條需求都對到風險控制與測試，每個風險控制都有驗證證據。審查時被追問『這個風險怎麼證明已降低？』，答案就在這張表裡。範例列為教學示意。

3

PART 3

# 上市路徑

## Getting to Market: EU / US / Taiwan

對應： MDR · FDA · 醫療器材管理法

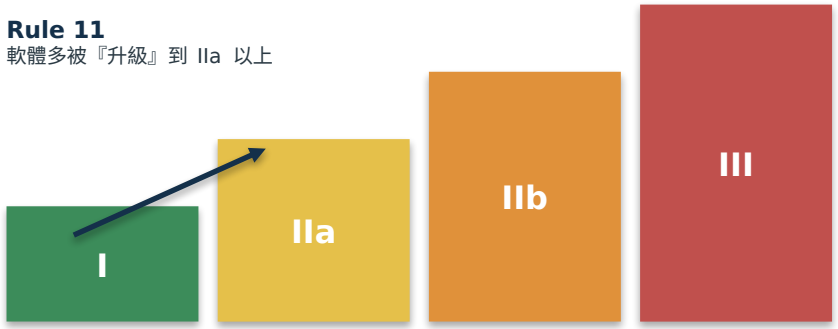
同一個產品，要在不同市場上市，走的路徑不同。
認識歐盟 MDR、美國 FDA、台灣 TFDA 三地的分級與查驗。

# 歐盟 MDR： Rule 11 讓多數醫療軟體『升級』

## CE 標章、公告機構、臨床評估

**MDR 風險分級（低 → 高）**

**Rule 11**
軟體多被『升級』到 IIa 以上



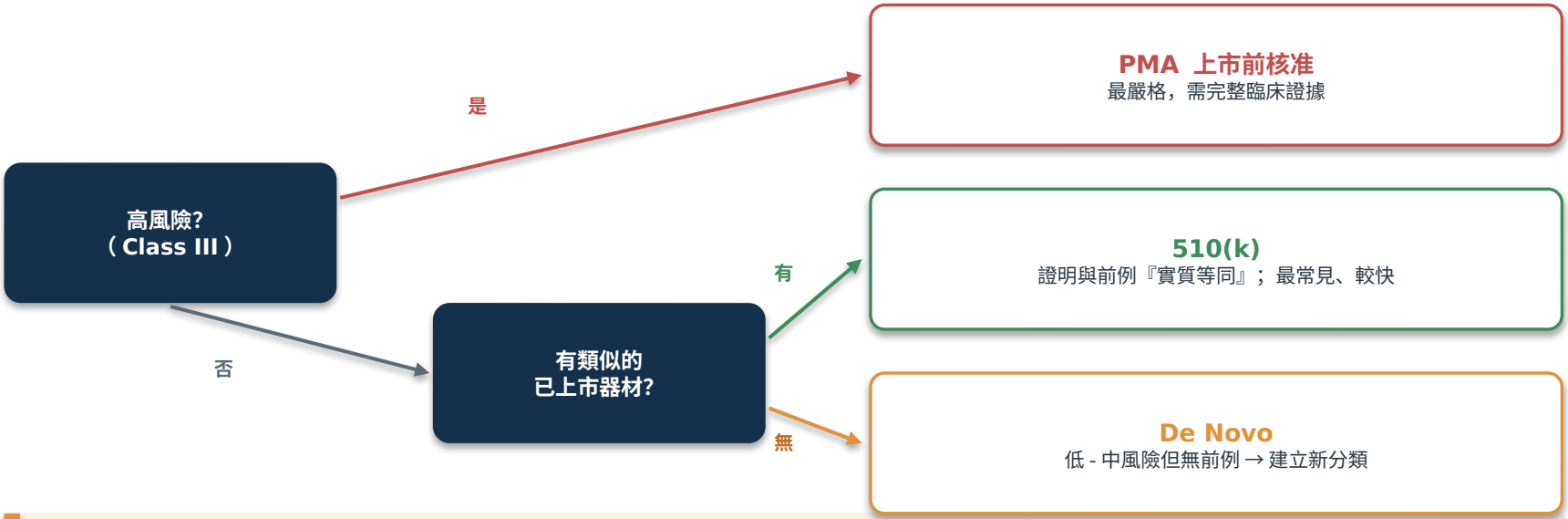

CE 標章；中高風險要公告機構（Notified Body）審查；臨床評估、 UDI 、上市後監督

**對 SaMD 的衝擊**
很多原本低風險的軟體被升級 → 要公告機構、更多證據
臨床評估要求提高
含 AI 還要疊加歐盟 AI 法（AI Act）對高風險 AI 的要求
**→ 進歐盟前先確認 Rule 11 把你歸到哪一級**

**教學重點** 歐盟 MDR 的震撼： 2017 年發布、 2021 年起全面適用的 MDR 用『Rule 11』專門管軟體，把許多『提供診斷 / 監測資訊』的軟體歸到 IIa 甚至更高——比舊制嚴很多，需要獨立『公告機構 (Notified Body)』審查、 CE 標章與臨床評估。若軟體含 AI ，還要疊加歐盟 AI 法對高風險 AI 系統的要求。進歐盟前務必先確認 Rule 11 把你歸到哪一級。

# 美國 FDA：三條主要路徑

依風險與『有沒有前例』決定走哪條




**教學重點**　FDA 三路徑怎麼選：有『類似的已上市器材』可比→走 510(k)（證明實質等同，最常見、最快）；是『新東西』但風險不高→走 De Novo（建立新分類）；高風險（如植入式、維生）→走 PMA（最嚴，要完整臨床試驗）。多數 AI/ 軟體醫材走 510(k) 或 De Novo。FDA 對 AI 醫材另有專門的變更管理機制 (PCCP,Part 4)。

# 台灣 TFDA： 醫療器材管理法 (2021)

## 本地上市的框架與分級

**醫療器材管理法（ 2021/5/1 施行）三等級**




依 IMDRF 原則分類； SaMD 適用；需查驗登記、 QMS （GMP）、 UDI 、上市後監督與通報

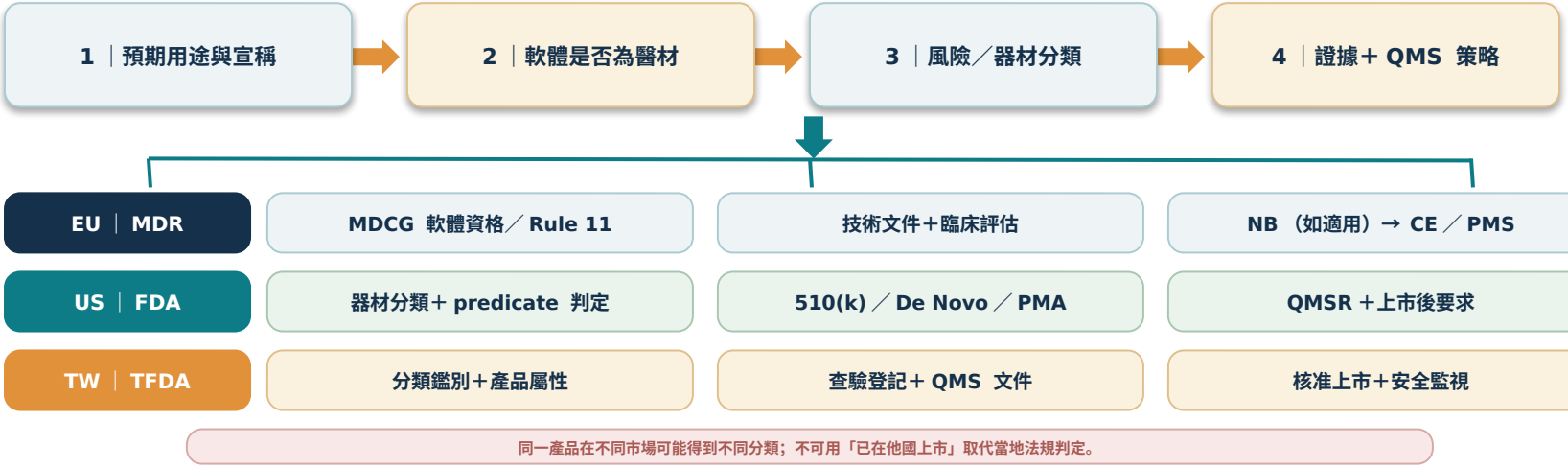
**實務提醒**

① 先用 TFDA 『分類分級查詢』確認等級
② 數位療法／ AI 軟體有對應審查考量
③ 可用國際（ FDA ／ MDR ）資料佐證
④ 三地分級不完全一致，要各自確認
**→ 上市前先諮詢，別做完才問**

**教學重點** 在地落地：台灣 2021 年施行『醫療器材管理法』專法，把醫材分成第一到第三等級（低 / 中 / 高風險），軟體醫材同樣適用，並依循 IMDRF 分類原則。要在台灣上市，需向 TFDA 查驗登記、符合品質系統、標示 UDI 。建議在開發早期就用 TFDA 的『分類分級查詢』確認你的產品屬於哪一級——三地（台 / 美 / 歐）分級不完全一致，要各自確認。

# EU 、 US 、 Taiwan： SaMD 三市場准入路徑

共同起點是預期用途、資格、分類、證據與 QMS；真正分流發生在法規分類規則、審查路徑、第三方參與與上市後義務。




來源： EU MDCG 2019-11 rev.1 （2025）； FDA device pathways ／ QMSR； TFDA 醫療器材法規與軟體分類指引

**教學提醒：建立「全球核心技術檔＋市場差異附件」。核心檔維持同一版的 intended use 、風險、架構、 V&V 與臨床證據；差異附件處理各市場分類與行政要求。**

4

PART 4

# AI ／ ML 醫材的特殊挑戰

## When the Device Learns

對應： GMLP · PCCP · 總產品生命週期

會『學習、更新』的 AI，挑戰了『產品定型後才審查』的傳統法規。
這一部教你 AI 醫材的特殊要求與最新的變更管理機制。

# 鎖定 vs 持續學習：AI 醫材的核心難題

傳統法規審『定型的產品』，但 AI 會變

## 鎖定型 Locked

v1 v1 v1 v1 v1

上市後不再自動改變

每次更新 → 重新驗證（可能重送審）

法規好處理；多數已核可 AI 醫材屬此類

**→ 穩定但更新慢**

## 持續學習 Adaptive

v1.0 v1.1 v1.2 v1.3 v1.4

隨新資料持續更新

審過的版本 ≠ 現在用的版本

風險：悄悄退化或產生偏誤（接 9.5 漂移）

**→ 需要新機制（PCCP）**

**教學重點** 核心矛盾：傳統醫材法規假設『產品定型後才審、審過就不變』。但 AI 的價值往往在於『能隨新資料持續改進』——這讓『你審查的版本』和『病人實際用的版本』可能不一樣。這正是 AI 醫材最大的法規難題。解法不是禁止更新，而是『事先講好怎麼更新』（PCCP，見後）。也呼應 9.5 的資料漂移與監測。

# GMLP：優良機器學習實務的指導原則

## 把 9.5 學的方法紀律，變成法規期待

1. 多方專業＋好軟體工程
2. 資料代表性、臨床相關
3. 訓練／測試獨立（防洩漏）
4. 人 -AI 團隊表現
5. 部署後監測、管再訓練風險

→

**9.5 學的方法紀律 → 法規期待**

先切再處理、外部驗證、校準、分族群公平、監測

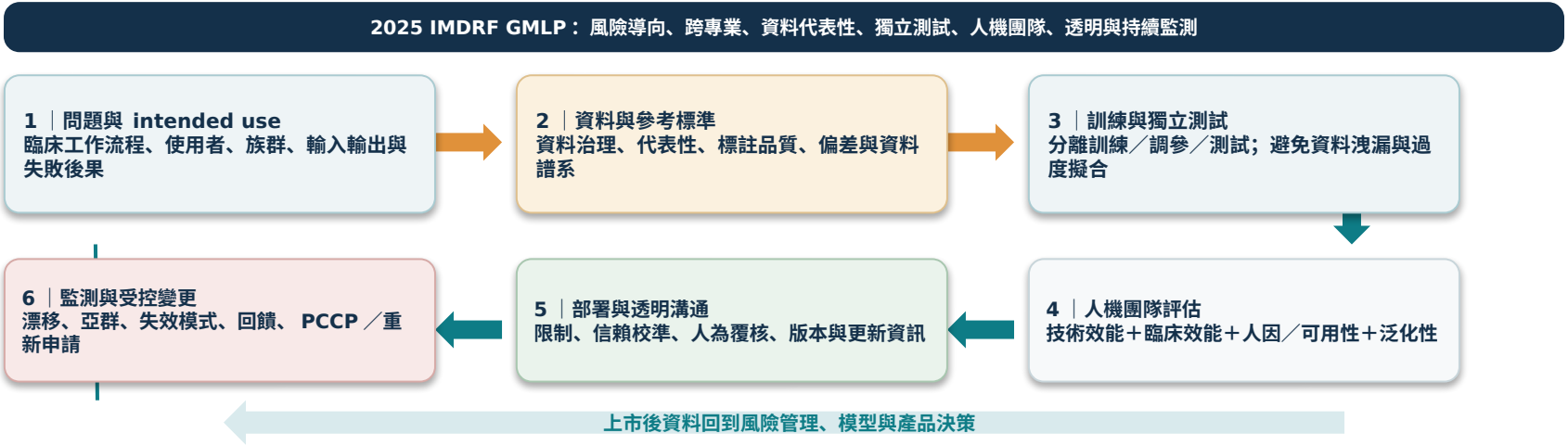
跨國共識： FDA ／ Health Canada ／ MHRA 2021； IMDRF 2025 十原則

**涵蓋總產品生命週期 TPLC**

**教學重點** GMLP （FDA/Health Canada/MHRA 2021;IMDRF 2025 十原則）其實就是把你在 9.5 學的醫療 AI 方法紀律——資料代表性、防洩漏、外部驗證、校準、分族群公平、部署後監測——變成『監管者期待你做到』的良好實務，並強調涵蓋『總產品生命週期 (TPLC) 』。換句話說， 9.5 的嚴謹方法不只是學術要求，也是上市的實務門檻。

# AI 醫材全生命週期：以 GMLP 管理 TPLC

從 intended use、代表性資料與獨立測試，到人機團隊評估、透明部署與漂移監測；每次學習或更新都必須回到風險與變更控制。




來源： IMDRF GMLP Guiding Principles （Final, 2025）； FDA ／ Health Canada ／ MHRA AI/ML principles

**教學提醒：模型效能只是產品證據的一部分。資料治理、參考標準、亞群、使用者行為、工作流程、版本控制與上市後監測共同決定 AI 醫材能否安全維持效能。**

# PCCP：讓 AI 合法地『持續更新』的機制

## 事先講好怎麼改，就不必每次都重送審

**上市時就『事先』交三份東西 → 照計畫更新，不必每次重送審**

**要改什麼**
Description of Modifications

**怎麼改、怎麼驗證**
Modification Protocol

**改了會影響什麼**
Impact Assessment

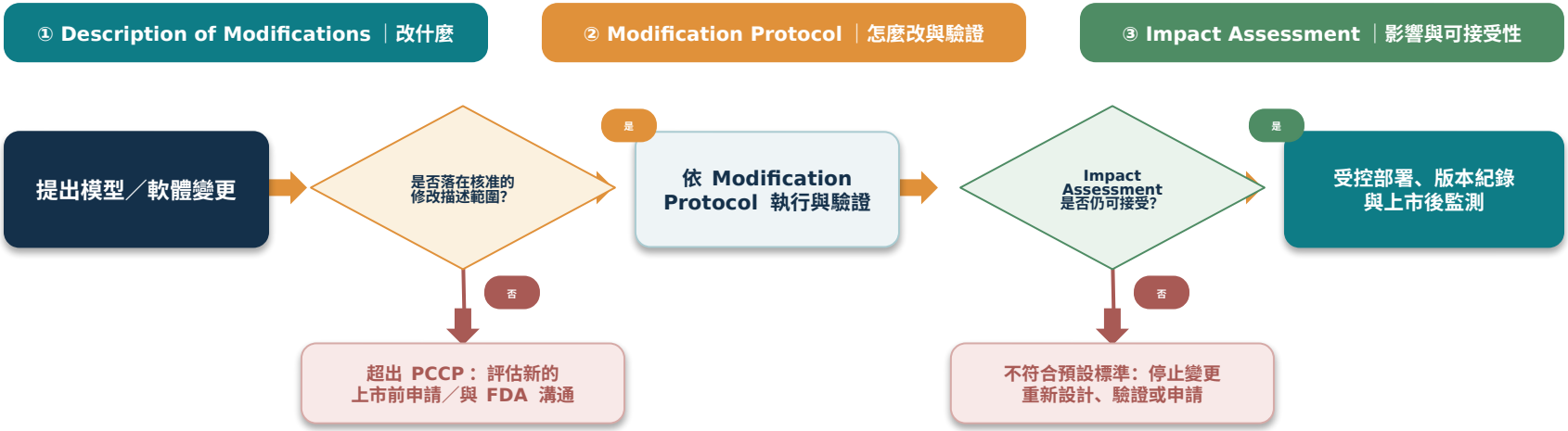
**為什麼是突破**
解決『AI 會變 vs 法規要定型』；在可控、可預期下允許更新，仍維持安全與效能

**時間點**
FDA 2024 年 12 月發布 AI 醫材 PCCP 最終指引

**教學重點** PCCP 是近年最重要的法規創新：與其禁止 AI 更新、或每次小改都重送審（不切實際），不如在上市時就『事先講清楚：我會怎麼改、用什麼方法驗證、會影響什麼』。監管者核准這個『計畫』後，你照計畫更新就合法，不必每次重審。 FDA 已於 2024 年 12 月發布 AI 醫材 PCCP 最終指引。這讓 AI 醫材既能持續改進、又維持監管——是 AI 健康科技的關鍵配套。

# PCCP： 把 AI 變更預先寫成可審查承諾

FDA 2024 年 12 月最終指引將 PCCP 組成明確化為修改描述、修改協定與影響評估；僅有模型更新清單，並不足以支持受控變更。




來源： FDA, Marketing Submission Recommendations for a PCCP for AI-Enabled Device Software Functions （Final, 2024-12）

**教學提醒： PCCP 不是變更免審通行證。每項修改必須落在核准範圍、依預定 protocol 執行、通過接受標準並留下版本與上市後證據；超出範圍就回到新的法規評估。**

5

PART 5

# 實務與實例

## Putting It Together

AI 視網膜篩檢軟體的法規旅程

把 Part 1–4 串起來：從『算不算醫材』一路走到上市與上市後，看一個 AI 健康科技產品的完整法規路徑。

# 實例： AI 糖尿病視網膜病變篩檢軟體

從意圖用途到上市後，一步步走

| 定用途 | 分級 | 建品質 | 驗證 | 送審 | 上市後 |
|---|---|---|---|---|---|
| 『協助醫師篩檢轉診』→ 屬醫材 | 診斷輔助 × 嚴重病況 → IMDRF III | QMS 、風險管理、軟體流程<br>13485 ／ 14971 ／ 62304 | 外部驗證、校準、分族群（接 9.5 ）<br>GMLP 、臨床評估 | 選路徑＋附 PCCP | 監測漂移、資安、通報 |

**教學重點** 看整條路：① 先確認『協助篩檢轉診』的宣稱讓它成為醫材；② 依風險分級；③ 從開發就內建品質 (13485) 、風險 (14971) 、軟體流程 (62304);④ 用 9.5 的嚴謹方法做臨床驗證 (GMLP);⑤ 選路徑送審並附 PCCP 讓模型能更新；⑥ 上市後持續監測漂移與資安。這就是把一個 AI 原型，變成合法、可持續的醫材。

# SaMD 臨床評估的三支柱：關聯、技術、臨床

有效臨床關聯回答「為何有意義」，分析／技術驗證回答「軟體是否做對」，臨床驗證回答「在目標情境中是否真的有用」。

**1 ｜有效臨床關聯**
**Valid clinical association**
疾病／狀態與軟體輸入、輸出或演算法之間，是否有可信且可適用的臨床關聯?

**2 ｜分析／技術驗證**
**Analytical / technical validation**
軟體是否正確、可靠、可重現地處理輸入並產生預期且精確的輸出?

**3 ｜臨床驗證**
**Clinical validation**
在目標族群、使用者與使用情境中，是否達成預期臨床目的與可接受效益風險?

**人因／可用性**
人與軟體是否能安全完成工作?

**泛化性／亞群**
不同場域、設備與族群是否穩定?

**持續臨床證據**
漂移、失效、更新與真實世界表現

**三支柱缺一不可；證據強度應與 SaMD 風險、宣稱與不確定性相稱，且須在全生命週期更新。**

來源： IMDRF SaMD N41—Clinical Evaluation； IMDRF N81 （2025）

**教學提醒： AUROC 或 sensitivity 很好，仍不等於臨床效益成立。必須同時說明目標族群、閾值、比較基準、使用流程、人機互動、失敗後果、亞群與真實世界監測。**

# 上市不是終點：上市後監督與資安

醫材的責任，延續到整個使用生命週期

## 上市後監督

- **監測**　真實世界效能（接 9.3 RWE 、 9.5 漂移）
- **通報**　不良事件要報主管機關
- **矯正**　CAPA，必要時召回
- **報告**　定期安全更新報告

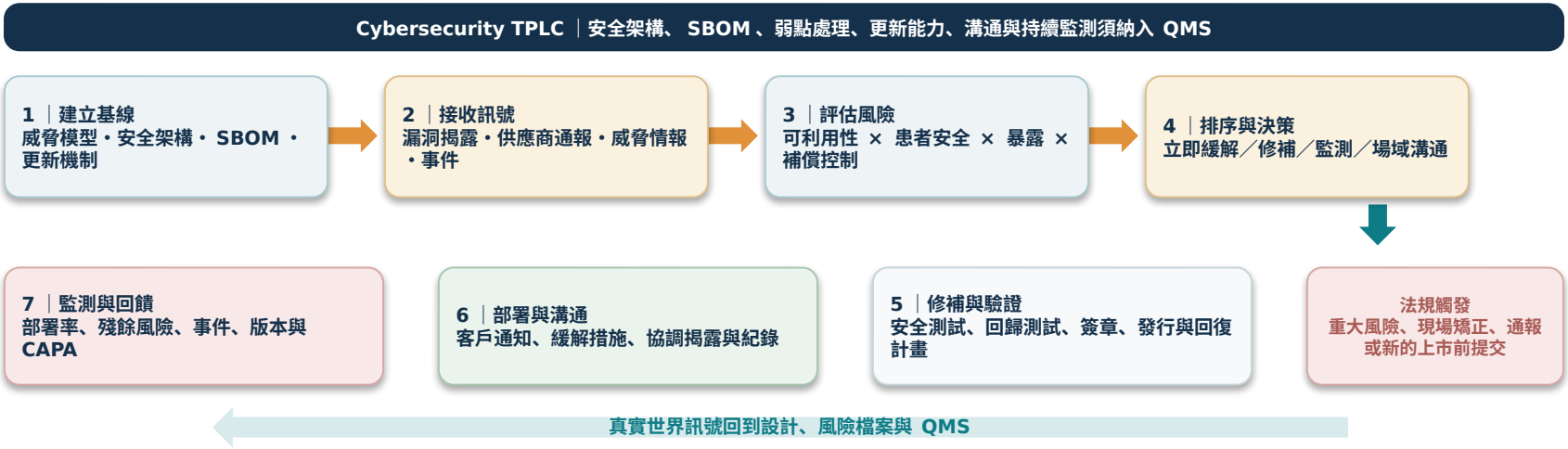
## 網路安全 Cybersecurity

- **風險**　軟體醫材是攻擊面 → 病人安全
- **做法**　威脅建模、漏洞管理、更新機制
- **資料**　保護病人資料（接 9.1）
- **法規**　越來越要求資安計畫

**教學重點**　全生命週期責任：醫材核准上市只是開始。你要持續監測真實世界效能（尤其 AI 會漂移，接 9.5）、通報不良事件、必要時召回或更新。網路安全也是重點——軟體醫材可能被攻擊而危害病人安全，法規越來越要求完整的資安計畫與漏洞管理。這與 9.1 的資料隱私、 9.5 的模型監測、 9.3 的真實世界證據都緊密相扣。

# 醫材資安的閉環：從 SBOM 到弱點修補、部署與監測

資安是患者安全與品質系統的一部分。產品需能辨識組件、接收漏洞、評估可利用性與臨床風險、快速更新並向使用者透明溝通。




來源： FDA Cybersecurity in Medical Devices Guidance （Final, 2026）； FDA Cybersecurity FAQs ／ Section 524B

**教學提醒：把「找到 CVE 」與「患者風險」連起來。 SBOM 讓範圍可見；威脅模型、可利用性、補償控制與臨床後果決定優先級；修補完成後仍要追蹤部署率與殘餘風險。**

# 常見錯誤與用 AI 協助法規的界線

## 及早規劃，別做完才發現要重來

### 常見錯誤 → 好習慣

- ✗ 以為是健康 App，其實是醫材
- ✗ 做完 MVP 才建 QMS → 重做
- ✗ 誇大療效 → 意外變高風險醫材
- ✓ 開發第一天就定意圖用途、查分級；及早內建品質／風險／軟體流程

### 用 AI 協助法規：可以／不可以

- ✓ 草擬技術文件、風險清單初稿
- ✓ 對照標準做缺口分析
- ✗ 讓 AI 『判定』分級當最終答案
- ✗ 用 AI 生成沒做的驗證／文件

**教學重點** 最實用的忠告：法規要『及早、內建』，不要『事後、補救』。開發第一天就問三件事——這算不算醫材？屬第幾級？要走哪條路徑？越早問越省。AI 可以加速文件與缺口分析，但『分級、送審策略、最終合規判斷』一定要諮詢法規專家與主管機關（TFDA/FDA/ 公告機構），別把 AI 的判斷當定案。

# 從研究原型到上市：每個階段該備好什麼

研究者最常卡在『論文做完了，產品卻上不了市』——差在中間這幾站

| ① 研究原型 | ② 臨床研究 | ③ 產品化 | ④ 送審 | ⑤ 上市後 |
|---|---|---|---|---|
| 寫下意圖用途<br>保留資料來源與版本<br>初版風險清單<br>論文：內部驗證 | IRB （依風險可能需主管機關核准）<br>預先註冊、外部驗證<br>接 9.4 ／ 9.5 | 導入 QMS 、 62304 流程<br>風險管理檔案、可用性測試<br>接 9.7 | 確認分級與路徑<br>技術文件＋臨床證據<br>AI 附 PCCP | 效能與漂移監測<br>不良事件通報<br>資安更新 |

**教學重點**　給研究者的提醒：學術研究原型不必一開始就全套 QMS ，但從第一天就寫下意圖用途、保留資料與版本紀錄、做風險清單，後面轉成上市產品時才不必打掉重來。涉及人體的醫材臨床研究，依風險可能需 IRB 及主管機關核准，事前務必確認。

# 本課總覽：一頁看完 SaMD 法規

從『算不算』到『上市後』

| 算不算醫材? | 第幾級? | 怎麼做? | 怎麼上市? | AI 特殊 |
|---|---|---|---|---|
| 看意圖用途，不看技術<br>**SaMD ／ IMDRF** | 資訊重要性 × 病況嚴重度<br>**IMDRF I–IV；各國分級** | 品質＋風險＋軟體流程，及早內建<br>**13485 ／ 14971 ／ 62304** | 選對路徑（台／美／歐）<br>**TFDA ／ FDA ／ MDR** | GMLP ＋ PCCP<br>**接 9.5** |

**教學重點**　帶走一句話：健康科技產品要真正進入臨床、幫到病人，除了有效 (9.4/9.5) 、好用 (9.7) 、能落地 (9.6/9.8) ，還要『合法上市』。法規不是敵人，而是把研究原型變成可信賴醫材的品質與安全門檻。核心四問——算不算醫材？第幾級？怎麼做（品質 / 風險 / 軟體）？怎麼上市？——越早想清楚，產品之路越順。

作業

# 帶回家作業 Take-home Assignment

## Regulatory Plan for a SaMD

Part A 觀念題 · Part B 實作題（附參考答案）

作業目標：能判斷產品算不算醫材、屬第幾級，規劃品質 / 風險 / 軟體流程，並為 AI 醫材設計上市與更新策略。

作業 Assignment

# 作業說明與繳交

建議 3–4 頁；重點是判斷與規劃，不是背條文

## 形式與繳交

- 形式：一份法規策略報告 (PDF/Word)
- 篇幅： Part A 每題 3–5 句； Part B 完整規劃
- 可畫意圖用途→分級→路徑的決策流程
- 獨立完成；可用 AI 協助但需自行核對並揭露
- 繳交期限：兩週後上課前

## 評分重點

- 意圖用途與『算不算醫材』判斷（25%）
- IMDRF 風險分級推理（20%）
- 三支柱（品質 / 風險 / 軟體）規劃（25%）
- 上市路徑與 AI 變更策略（20%）
- 上市後與資安意識（10%）

**情境（Part B 共用）：** 一款用手機鏡頭分析傷口照片、判斷『是否感染、建議就醫』的 AI App。

**教學重點** 寫作提醒：每個判斷都要說『為什麼』——這個宣稱讓它算不算醫材、風險為何落在那一級、所以要做什麼。老師看的是你能不能把『算不算→第幾級→怎麼做→怎麼上市』這條法規主線，實際用在一個 AI 健康科技產品上。

# 四題觀念題（每題 3–5 句）

用你的話講清楚

**A1** 什麼是 SaMD? 為什麼『算不算醫材』看意圖用途而非技術? 請各舉一個算與不算的例子。

**A2** IMDRF 用哪兩個維度決定風險分級? 請用一個例子說明怎麼落到某一級。

**A3** IEC 62304 的 A/B/C 分級是在評『軟體有多安全』嗎? 它到底決定什麼?

**A4** AI 醫材『會持續學習』為何對傳統法規是難題? PCCP 怎麼解決它?

**教學重點** 提示: A1 想意圖用途、醫療目的; A2 想資訊重要性 × 病況嚴重度; A3 想失效傷害→流程嚴謹度，非產品安全度; A4 想審過的≠在用的、事先講好怎麼改。

作業 · Part B ｜實作題

# 為傷口 AI App 做法規規劃

## 手機分析傷口照片，判斷感染並建議就醫

**為這款傷口 AI App，請完成：**

B1　它算不算醫療器材？請用『意圖用途』說明理由。

B2　用 IMDRF 兩維度，推估它的風險類別，並說明推理。

B3　列出你會在開發早期導入的三大標準，各一句說明要做什麼。

B4　它是 AI 醫材，你會怎麼規劃『模型更新』的合規策略？

B5　列出兩件『上市後』你必須持續做的事（含資安）。

**教學重點**　重點： B1 判斷 / 建議就醫→很可能是醫材； B2 診斷輔助 × 傷口感染（嚴重度中）→約 II–III;B3 ISO 13485/14971/IEC 62304;B4 提交 PCCP（事先講好怎麼更新）;B5 效能漂移監測、不良事件通報、資安 / 漏洞管理。

延伸閱讀 References

# 想更深入可以看這些

## 權威標準與各地法規

| 主題 | 來源 |
| --- | --- |
| SaMD 框架 | IMDRF SaMD 系列文件 ( 定義、風險分級、 GMLP);imdrf.org |
| 品質 / 風險 / 軟體 | ISO 13485(QMS) 、 ISO 14971 （風險）、 IEC 62304 （軟體）、 IEC 62366-1 （可用性） |
| 歐盟 | EU MDR (2017/745) Rule 11 ； 歐盟 AI 法 (AI Act) |
| 美國 | FDA SaMD/AI-ML 專區； PCCP 最終指引 (2024/12);GMLP |
| 台灣 | 醫療器材管理法 (2021);TFDA 分類分級查詢與查驗登記 |
| AI 醫材 | GMLP 十原則 (IMDRF 2025);FDA AI/ML action plan |

**教學重點** 這一課與整個單元 9 緊密相扣：意圖用途與 AI 方法接 9.5 ，可用性接 9.7 ，上市後真實世界證據接 9.3 ，隱私資安接 9.1 ，臨床證據接 9.4 。真正要送審時，務必以主管機關（TFDA/FDA/ 公告機構）最新公告與專業法規顧問為準——法規會更新，本課提供的是『思考框架』。

法規與品質（軟體醫材 SaMD） · SaMD Regulation & Quality

# 算不算 · 第幾級 · 怎麼做 · 怎麼上市

法規不是敵人，而是把研究原型變成可信賴醫材的門檻

*SaMD · IMDRF · ISO 13485/14971 · IEC 62304 · MDR/FDA/TFDA · GMLP/PCCP*

# 案例應用：這個工具算不算醫療器材

案例 Q ｜ AI 照護紀錄摘要工具對長照機構交班效率與紀錄品質之影響

**① 本單元教了什麼**

醫材屬性判定、 IMDRF 風險分類，以及品質系統的三層架構。

**② 案例怎麼用**

- 關鍵在預期用途：本工具僅彙整既有紀錄，不提供診斷或治療建議。
- 使用者於送出前逐項核對，人為判斷未被取代——此為不列為醫材之主要理由。
- 惟單元 9.2 顯示 12 次真的遺漏而未警示；若被當成安全網使用，定位即改變。
- 若日後加入風險預警功能，依 IMDRF 分類將落入 Category II 以上。
- 本研究於論文中明確聲明所評估者為現行版本之預期用途。

**③ 產出什麼證據**

醫材屬性判定表（次頁），作為機構後續功能擴充之決策依據。

**④ 承接關係**

上游：承自 9.9 之 TREND 與 COREQ 自評表 ｜ 下游：交棒 9.11，處理交班紀錄中的個資問題。

**教學重點** 醫材與否不看技術，看預期用途。同一套模型，寫成「協助彙整」與寫成「提示風險」，法規義務差了好幾個等級——這句話要寫進使用說明，不是寫進行銷文案。

# 示範產物：醫材屬性判定表

逐項判定並保留紀錄；預期用途一旦變更，本表須重新評估

| 判定要素 | 本工具之情形 | 判定 | 若功能擴充之影響 |
|---|---|---|---|
| 預期用途 | 彙整既有交班紀錄，產生摘要供人工核對 | 非診斷或治療 | 若加入風險預警，即進入醫材範疇 |
| 是否影響臨床決策 | 使用者須逐項核對後始送出 | 間接且可被攔截 | 若改為自動送出，攔截機制消失 |
| 資訊之嚴重性 | 輸出為既有資訊之重述，非新增判斷 | 低 | 若產生新的風險評分，嚴重性提高 |
| 醫療情境之危急程度 | 住宿式長照之例行交班 | 非危急 | 若延伸至急性後期或加護場域，等級提高 |
| IMDRF 分類 | 現行版本不落入軟體醫材定義 | 非 SaMD | 加入預警功能後預估為 IMDRF Category II |
| 結論 | 以現行預期用途，不列為醫療器材 | — | 任何功能變更均須重新判定並保留紀錄 |

**教學重點**　第二列是本案例最脆弱的一環：不列為醫材的理由建立在「使用者會逐項核對」。而單元 9.6 顯示編輯比例為 0.46——過半摘要未經修改，日誌卻無法區分「核對後無需修改」與「根本未核對」。這個落差要如何釐清，是實務上真正的難題。